

Encuesta Integral de Madurez CMMC / NIS2 / ENS

Evaluación de indicadores, métricas y prácticas de ciberseguridad

Versión: 1.0

Alcance: Organizaciones establecidas en España, con ambición (confesa o clandestina) de jugar en ligas internacionales.

Confidencialidad: Uso interno y análisis agregado.

0. Datos generales de la organización

0.1. Nombre de la organización

- ☐ Prefiero no indicarlo (usaremos un código)
- ☐ Lo indicaré al analista (fuera de este formulario)
- ☐ Lo indicaré aquí: _____

0.2. Sector principal de actividad (marcar la opción que mejor describa su realidad)

- ☐ Administración pública (AGE, CCAA, EELL)
- ☐ Sanidad y servicios sociales
- ☐ Energía y utilities
- ☐ Industria manufacturera (incluida industria 4.0)
- ☐ Transporte y logística
- ☐ Financiero y seguros
- ☐ TIC / proveedores de servicios digitales
- ☐ Defensa y aeroespacial
- ☐ Educación e I+D
- ☐ Otro (especificar): _____

0.3. Tamaño aproximado de la organización (empleados)

- ☐ Micro (1-9)
- ☐ Pequeña (10-49)
- ☐ Mediana (50-249)
- ☐ Grande (250-999)
- ☐ Muy grande (≥ 1.000)

0.4. Exposición internacional

- ☐ Operamos sólo en España
- ☐ Operamos en la UE
- ☐ Operamos en la UE y fuera de la UE
- ☐ Formamos parte de cadenas de suministro de defensa / DoD
- ☐ Aspiramos a todo lo anterior, pero todavía no

1. Gobernanza, estrategia y cultura de ciberseguridad

1.1. Estrategia formal de ciberseguridad

¿Dispone la organización de una estrategia o plan director de ciberseguridad aprobado por el máximo órgano de gobierno?

- ☐ No existe ningún documento formal; vivimos peligrosamente
- ☐ Existe un documento informal, no aprobado por el órgano de gobierno
- ☐ Existe y fue aprobado hace más de 3 años, sin revisión reciente
- ☐ Existe y se revisa al menos cada 2-3 años
- ☐ Existe, se revisa al menos anualmente y se alinea con riesgos corporativos

1.2. Participación del órgano de gobierno

¿Con qué frecuencia recibe el órgano de gobierno (Consejo, Comité de Dirección, etc.) información formal sobre riesgos y madurez de ciberseguridad?

- ☐ Nunca (confiamos en la providencia tecnológica)
- ☐ Sólo cuando ocurre un incidente grave
- ☐ Al menos una vez al año
- ☐ Trimestralmente
- ☐ Mensualmente o más

1.3. Rol formal de seguridad (CISO / equivalente)

¿Existe una figura responsable de seguridad de la información / ciberseguridad formalmente designada?

- ☐ No, la seguridad “va de todos” y por tanto de nadie
- ☐ Sí, pero compagina la seguridad con otras funciones (TI, operaciones, etc.)
- ☐ Sí, responsable dedicado a tiempo parcial
- ☐ Sí, responsable dedicado a tiempo completo
- ☐ Sí, responsable dedicado y con equipo propio

1.4. Integración del riesgo ciber en la gestión global del riesgo

¿Cómo se integra el riesgo de ciberseguridad en la matriz de riesgos corporativa?

- ☐ No se incluye explícitamente
- ☐ Se menciona de forma genérica, sin métricas asociadas
- ☐ Se incluye con algunos indicadores cualitativos
- ☐ Se incluye con indicadores cuantitativos y umbrales
- ☐ Se gestiona como riesgo estratégico clave con indicadores periódicos

1.5. Coordinación con cumplimiento normativo (NIS2, ENS, DORA, RGPD, etc.)

¿Qué grado de alineación existe entre ciberseguridad y cumplimiento normativo?

- ☐ Se gestionan por separado, con cierta fricción creativa
- ☐ Se coordinan puntualmente para auditorías e inspecciones
- ☐ Hay una coordinación estructurada, pero sin métricas compartidas
- ☐ Hay alineación plena, con indicadores y objetivos comunes
- ☐ Existe un programa integrado de GRC (Governance, Risk & Compliance)

2. Marco de referencia y alineamiento CMMC / NIST / ENS

2.1. Marcos de referencia utilizados

¿Qué marcos o normas se utilizan como referencia explícita en la organización? (marque todas las que apliquen)

- ☐ Ninguno en particular (modo creativo puro)
- ☐ NIST Cybersecurity Framework (CSF)
- ☐ NIST SP 800-171
- ☐ CMMC (algún nivel)
- ☐ ISO/IEC 27001
- ☐ Esquema Nacional de Seguridad (ENS)
- ☐ Otros (especificar): _____

2.2. Uso de CMMC como referencia

¿Cómo se utiliza CMMC en su organización?

- ☐ No se utiliza ni se contempla
- ☐ Se conoce de forma teórica, pero no se aplica
- ☐ Se usa como checklist de medida informal
- ☐ Se ha realizado al menos una autoevaluación frente a CMMC/NIST
- ☐ Se ha realizado una evaluación formal externa o se prepara certificación

2.3. Nivel de madurez CMMC objetivo (si aplica)

¿Cuál es el nivel de CMMC que se considera objetivo realista (formal o informal) para la organización?

- ☐ Ninguno / no aplica
- ☐ Nivel 1 (Fundacional)
- ☐ Nivel 2 (Avanzado / NIST SP 800-171 completo)
- ☐ Nivel 3 (Experto / NIST SP 800-171 + 800-172)
- ☐ Diferenciado por áreas/filiales (especificar en comentarios)

2.4. Mapeo ENS / NIS2 / DORA → CMMC / NIST

¿Cuál es el estado del mapeo entre requisitos normativos españoles/europeos y marcos CMMC/NIST?

- ☐ No existe ningún mapeo formal
- ☐ Hay un mapeo parcial (ej. ENS vs. NIST CSF)
- ☐ Hay un mapeo bastante completo ENS/NIS2 → NIST 800-171
- ☐ Hay un mapeo formal ENS/NIS2/DORA → CMMC nivel objetivo
- ☐ El mapeo se revisa periódicamente y se utiliza para auditorías

3. Gestión de activos, configuración y vulnerabilidades

3.1. Inventario de activos

¿Cómo describiría el estado de su inventario de activos (hardware, software, datos, servicios)?

- ☐ No existe inventario centralizado
- ☐ Existe inventario parcial, incompleto o desactualizado
- ☐ Inventario razonablemente completo, con alguna carencia puntual

- ☐ Inventario completo y actualizado al menos trimestralmente
- ☐ Inventario completo, automatizado y con dueño asignado a cada activo

3.2. Gestión de parches y vulnerabilidades

¿Cuál es el plazo medio para aplicar parches críticos de seguridad en sistemas expuestos a internet?

- ☐ Más de 90 días (lo urgente nunca deja tiempo a lo importante)
- ☐ Entre 31 y 90 días
- ☐ Entre 15 y 30 días
- ☐ Menos de 14 días
- ☐ Menos de 7 días, con priorización basada en riesgo

3.3. Análisis de vulnerabilidades

¿Con qué frecuencia realiza análisis de vulnerabilidades sobre los sistemas críticos?

- ☐ Nunca / muy rara vez
- ☐ Una vez al año
- ☐ Trimestralmente
- ☐ Mensualmente
- ☐ De forma continua, con priorización basada en riesgo

3.4. Métricas sobre vulnerabilidades

¿Qué métricas emplea para monitorizar la situación de vulnerabilidades? (marque todas las que apliquen)

- ☐ Número total de vulnerabilidades abiertas
- ☐ Número de vulnerabilidades críticas abiertas por activo
- ☐ Tiempo medio de resolución por criticidad
- ☐ Porcentaje de activos sin vulnerabilidades críticas abiertas
- ☐ Otras (especificar): _____
- ☐ No se monitoriza con métricas; se actúa "por sensaciones"

4. Control de acceso e identidad

4.1. Gestión de cuentas y privilegios

¿Cómo se gestionan las cuentas de usuario y los privilegios?

- ☐ No hay un proceso formal; se crean y rara vez se eliminan
- ☐ Hay proceso básico para altas y bajas, sin revisión periódica de privilegios
- ☐ Se revisan los privilegios al menos una vez al año
- ☐ Hay políticas de mínimos privilegios y revisiones periódicas estructuradas
- ☐ Uso avanzado de IAM, roles, recertificaciones periódicas y automatización

4.2. Autenticación multifactor (MFA)

¿Qué porcentaje aproximado de cuentas con acceso a sistemas críticos utiliza MFA robusta?

- ☐ 0-20 %
- ☐ 21-50 %
- ☐ 51-80 %

- ☐ 81–95 %
- ☐ 96–100 % (o tenemos un plan casi malignamente ambicioso para llegar)

4.3. Accesos remotos

¿Cómo se protegen los accesos remotos a sistemas críticos (incluido teletrabajo)?

- ☐ Sin medidas específicas más allá de usuario/contraseña
- ☐ VPN básica con autenticación simple
- ☐ VPN con MFA y segmentación limitada
- ☐ Acceso remoto con MFA, segmentación por roles y monitorización
- ☐ Acceso remoto con enfoque Zero Trust (verificación continua, microsegmentación)

5. Protección de información sensible (CUI-like, datos críticos)

5.1. Identificación de información sensible

¿Dispone la organización de un inventario o categorización formal de datos sensibles/Críticos/CUI-like?

- ☐ No, los datos sensibles se intuyen pero no se nombran
- ☐ Existe categorización informal, sin política aprobada
- ☐ Existe política formal y categorización de alto nivel
- ☐ Existe clasificación detallada y se aplica en sistemas clave
- ☐ Existe clasificación integral, con etiquetado y controles técnicos asociados

5.2. Cifrado en reposo

¿Qué porcentaje aproximado de los datos sensibles se cifra en reposo con medios controlados?

- ☐ 0–20 %
- ☐ 21–50 %
- ☐ 51–80 %
- ☐ 81–95 %
- ☐ 96–100 % (o ese es el objetivo calendarizado)

5.3. Cifrado en tránsito

¿Qué nivel de cifrado en tránsito se aplica a la información sensible?

- ☐ No existe garantía consistente de cifrado en tránsito
- ☐ Cifrado puntual en algunos servicios (ej. web externa)
- ☐ Cifrado generalizado en canales críticos
- ☐ Cifrado sistemático, con políticas de uso de TLS y revisiones periódicas
- ☐ Cifrado sistemático con inspección segura, monitoreo y gestión de claves

5.4. Control de exfiltración y filtraciones accidentales

¿Qué controles existen para evitar la exfiltración o filtración accidental de información sensible?

- ☐ Ningún control específico (solo buena voluntad)
- ☐ Reglas básicas (limitación de uso de dispositivos externos, etc.)
- ☐ Soluciones DLP en áreas concretas
- ☐ Soluciones DLP extendidas, con alertas y procesos de respuesta

- ☐ Control avanzado, incluyendo DLP, CASB, monitorización de comportamiento y revisiones periódicas

6. Monitorización, detección y respuesta a incidentes

6.1. Monitorización de seguridad

¿Qué grado de monitorización de seguridad existe sobre sistemas y redes críticas?

- ☐ Prácticamente nula (sólo se ve lo que ya arde)
- ☐ Logs básicos, sin correlación centralizada
- ☐ SIEM o equivalente sobre parte de los sistemas
- ☐ SIEM/SOC sobre sistemas críticos, con reglas y casos de uso definidos
- ☐ Monitorización continua 24/7 con SOC interno o externo y mejora continua

6.2. Métricas de detección y respuesta

¿Qué métricas se miden y se reportan regularmente? (marque todas las que apliquen)

- ☐ Número de incidentes detectados
- ☐ Tiempo medio de detección (MTTD)
- ☐ Tiempo medio de respuesta (MTTR)
- ☐ Porcentaje de incidentes con análisis de causa raíz
- ☐ Porcentaje de incidentes con plan de acción completo y seguimiento
- ☐ Ninguna métrica formal; gestionamos “por narrativa”

6.3. Plan de respuesta a incidentes

¿Dispone la organización de un plan formal de respuesta a incidentes?

- ☐ No existe plan formal
- ☐ Existe borrador sin aprobar
- ☐ Existe plan aprobado, pero no se ha probado
- ☐ Existe plan aprobado y probado al menos una vez en los últimos 2 años
- ☐ Existe plan aprobado, probado anualmente con simulacros realistas

6.4. Ejercicios y simulacros

¿Qué tipo de ejercicios se realizan para comprobar la capacidad de respuesta?

- ☐ Ninguno
- ☐ Ejercicios de escritorio ocasionales
- ☐ Simulacros técnicos limitados (ej. ataque simulado de phishing)
- ☐ Simulacros integrales que incluyen negocio, TI, comunicación, legal
- ☐ Ejercicios avanzados tipo “purple team” o similares

7. Formación, concienciación y cultura

7.1. Formación general en ciberseguridad

¿Qué porcentaje aproximado de la plantilla recibe formación anual en ciberseguridad?

- ☐ 0–20 %
- ☐ 21–50 %
- ☐ 51–80 %

- ☐ 81–95 %
- ☐ 96–100 %

7.2. Formación específica para roles clave

¿Reciben formación específica en ciberseguridad los perfiles de alto riesgo (TI, desarrollo, directivos, personal con acceso a datos sensibles)?

- ☐ No, todos reciben (o no reciben) lo mismo
- ☐ Formación específica ocasional
- ☐ Formación específica regular pero no sistemática
- ☐ Programas estructurados por rol, revisados periódicamente
- ☐ Programas estructurados, medidos y vinculados a desempeño

7.3. Simulaciones de phishing y pruebas de comportamiento

¿Se realizan campañas de simulación de phishing u otras pruebas de comportamiento?

- ☐ No, nunca
- ☐ Sí, puntualmente (una vez al año o menos)
- ☐ Sí, varias veces al año
- ☐ Sí, periódicamente y con métricas de clics y reporte
- ☐ Sí, periódicamente, con métricas, segmentación y mejora de contenidos

7.4. Cultura y reporte interno

¿Cómo describiría la disposición del personal a reportar incidentes o sospechas?

- ☐ “Si no lo veo, no existe” (poca cultura de reporte)
- ☐ Se reporta cuando es muy evidente
- ☐ Existe canal formal, pero infrautilizado
- ☐ Se reporta activamente, el personal conoce el canal
- ☐ Cultura madura: se reporta y se explican resultados y mejoras

8. Gestión de proveedores y cadena de suministro

8.1. Identificación de proveedores críticos

¿Identifica la organización a los proveedores TIC y de servicios más críticos para su operación?

- ☐ No de forma sistemática
- ☐ Parcialmente, para algunos contratos relevantes
- ☐ Sí, hay un listado de proveedores críticos
- ☐ Sí, listado con criterios, niveles de criticidad y revisión periódica
- ☐ Sí, con evaluación de riesgos específica por proveedor crítico

8.2. Requisitos de seguridad en contratos

¿Incluye requisitos formales de seguridad en contratos con proveedores críticos (alineados con NIS2, DORA, CMMC-like, etc.)?

- ☐ No, todavía confiamos en la buena fe y el NDA
- ☐ Sí, cláusulas genéricas de seguridad
- ☐ Sí, cláusulas que mencionan estándares (ISO, ENS, NIST, etc.)

- ☐ Sí, cláusulas con requisitos concretos y verificables
- ☐ Sí, cláusulas con requisitos concretos, métricas y derecho de auditoría

8.3. Evaluación periódica de proveedores

¿Se evalúa la postura de seguridad de proveedores críticos de forma periódica?

- ☐ No, sólo valoramos precio y servicio
- ☐ Ocasionalmente, coincidiendo con renovaciones de contrato
- ☐ Sí, al menos cada 2-3 años
- ☐ Sí, al menos anual
- ☐ Sí, con métricas, scoring y seguimiento de planes de acción

9. Documentación, evidencias y auditabilidad

9.1. System Security Plan (SSP) o equivalente

¿Dispone la organización de un documento que describa de forma estructurada los sistemas, controles y riesgos (equivalente a un SSP CMMC)?

- ☐ No
- ☐ Borrador inicial sin completar
- ☐ Documento existente pero desactualizado
- ☐ Documento actualizado en los últimos 2 años
- ☐ Documento vivo, actualizado al menos anualmente y vinculado a planes

9.2. Planes de acción y hitos (POA&M o equivalente)

¿Se gestionan formalmente los planes de acción derivados de auditorías, evaluaciones o incidentes?

- ☐ No, cada uno recuerda “lo suyo”
- ☐ Hay listas ad-hoc sin seguimiento global
- ☐ Existe registro central de acciones, sin priorización clara
- ☐ Existe registro central priorizado, con responsables y fechas
- ☐ Registro central priorizado, seguimiento regular y reportes al gobierno

9.3. Evidencias de cumplimiento

¿Dispone de evidencias documentadas para demostrar el cumplimiento de sus controles clave?

- ☐ Poco o nada documentado
- ☐ Evidencias dispersas, no centralizadas
- ☐ Evidencias centralizadas para controles principales
- ☐ Evidencias centralizadas y catalogadas por marco/norma
- ☐ Gestión sistemática de evidencias, con revisiones de calidad

10. Métricas, indicadores e índices compuestos

10.1. Definición de KPIs/KRIs de ciberseguridad

¿Dispone la organización de un conjunto formal de KPIs/KRIs de ciberseguridad?

- ☐ No
- ☐ Algunos indicadores aislados, sin marco común
- ☐ Conjunto básico de indicadores (ej. nº incidentes, nº vulnerabilidades)

- ☐ Conjunto estructurado, vinculado a objetivos y riesgos
- ☐ Conjunto estructurado, revisado regularmente y alineado con negocio

10.2. Frecuencia de reporte de métricas

¿Con qué frecuencia se reportan estas métricas a la dirección?

- ☐ No se reportan
- ☐ Anualmente
- ☐ Trimestralmente
- ☐ Mensualmente
- ☐ Semanalmente o más en contextos críticos

10.3. Índices de madurez / scoring interno (CMMC-like / SPRS-like)

¿Se utiliza algún índice de madurez o scoring interno basado en marcos como CMMC, NIST o ENS?

- ☐ No
- ☐ Sí, índice cualitativo
- ☐ Sí, índice cuantitativo básico (porcentaje de controles implantados)
- ☐ Sí, índice cuantitativo ponderado y revisado periódicamente
- ☐ Sí, índice cuantitativo integrado en decisiones de inversión y riesgo

11. Inversión, ROI y mejora continua

11.1. Inversión en ciberseguridad

¿Cómo describiría la evolución de la inversión en ciberseguridad en los últimos 3 años?

- ☐ Ha disminuido (la esperanza es barata)
- ☐ Se ha mantenido estable pese al incremento de amenazas
- ☐ Ha aumentado ligeramente (ajustes tácticos)
- ☐ Ha aumentado de forma significativa (cambio estratégico)
- ☐ Se ha asociado de forma explícita a análisis de riesgos y ROI

11.2. Evaluación del retorno (ROI) de iniciativas de ciberseguridad

¿Se analiza el retorno (tangible o intangible) de los proyectos de ciberseguridad?

- ☐ No, se asume como “coste hundido y necesario”
- ☐ De forma cualitativa (encuestas, percepciones)
- ☐ De forma cuantitativa en algunos proyectos críticos
- ☐ De forma sistemática, usando métricas de riesgo evitado / pérdidas evitadas
- ☐ Integrado en un marco de valoración actuarial o de valor en riesgo (VaR)

11.3. Prioridad de mejoras

¿Cómo se priorizan las iniciativas de mejora de ciberseguridad?

- ☐ Por urgencias del día a día
- ☐ Por cumplimiento normativo mínimo
- ☐ Por impacto estimado sobre riesgo de negocio
- ☐ Por impacto sobre riesgo y sinergias con otros proyectos
- ☐ Mediante un marco estructurado de priorización (riesgo, coste, ROI, dependencia)

12. Percepción global y ambición

12.1. Autopercepción de madurez CMMC-like

En una escala de 0 a 5, donde 0 es “totalmente inmaduro” y 5 es “casi un modelo de referencia”, ¿cómo valoraría la madurez global de su organización en ciberseguridad?

- ☐ 0
- ☐ 1
- ☐ 2
- ☐ 3
- ☐ 4
- ☐ 5

12.2. Ambición a 3 años

¿Dónde le gustaría situarse en esa escala dentro de 3 años?

- ☐ Igual que ahora (la estabilidad también tiene su encanto)
- ☐ +1 punto
- ☐ +2 puntos
- ☐ +3 puntos o más
- ☐ Aspiramos a ser referencia nacional / sectorial

12.3. Comentarios adicionales

Espacio para matices, filias, fobias y ambiciones inconfesables de mejora en ciberseguridad:

Fin del cuestionario. Gracias por su paciencia, su honestidad y su contribución a un ecosistema digital algo menos incendiario.